Passiver Web-Security-Prüfbericht: HTTP-Sicherheitsheader

Ziel: Öffentliche Startseite der Johann-Rieder-Realschule Rosenheim

Geprüfte URL: `https://www.johann-rieder-realschule.de/`

Methode: Passive, manuelle Sichtprüfung der HTTP-Response-Header in Chrome DevTools (Netzwerk-Tab)

Status: Vorläufig

1. Umfang und Abgrenzung

Geprüft wurde ausschließlich die Antwort auf einen normalen Seitenaufruf der Startseite. Es wurden keine Scans, Login-Versuche, Fuzzing oder sonstigen aktiven Tests durchgeführt. Nicht geprüft wurden Unterseiten, Cookies, TLS-Konfiguration und Serverversionen.

2. Ergebnisse

Header	Ergebnis	Einschätzung
`Strict-Transport-Security`	Nicht vorhanden	Niedrig
`Content-Security-Policy`	Nicht vorhanden	Niedrig bis mittel
`X-Content-Type-Options`	Vorhanden: `[Wert]`	Kein Handlungsbedarf, wenn `nosniff`
`Referrer-Policy`	Vorhanden: `[Wert]`	`[Wert bewerten]`
`Permissions-Policy`	Nicht vorhanden	Informativ

3. Bewertung

Die fehlenden Header sind **Härtungsempfehlungen und keine nachgewiesenen Schwachstellen**. Es wurde keine ausnutzbare Sicherheitslücke festgestellt. Bei einer überwiegend statischen Informationsseite ist das Risiko insgesamt gering. Die Einschätzungen in der Tabelle sind eine Einordnung des Prüfers und keine formale Risikobewertung.

4. Empfehlungen (nach Priorität)

1. **HSTS:** Prüfen, ob die Seite vollständig über HTTPS erreichbar ist und HTTP sauber weiterleitet. Danach `Strict-Transport-Security` mit einem zunächst moderaten `max-age` setzen.
2. **Content-Security-Policy:** Eine zur Seite passende Policy entwickeln und zunächst im `Content-Security-Policy-Report-Only`-Modus testen, damit nichts kaputtgeht.
3. **Referrer-Policy:** Den vorhandenen Wert prüfen. `strict-origin-when-cross-origin` ist ein üblicher, sinnvoller Wert.
4. **Permissions-Policy:** Optional, je nachdem, welche Browserfunktionen die Seite tatsächlich nutzt.

5. Offene Punkte

- Werte der vorhandenen Header eintragen
- Gegenprüfung mit securityheaders.com oder Mozilla Observatory
- Nicht untersucht: `X-Frame-Options` bzw. `frame-ancestors`, Cookie-Flags, `Server`-Header